

Security Testing Tools: Wapiti, OWASP ZAP and Netsparker—A Comparison

With the vast use of the Internet, websites have become complex and impose increasing challenge in securing them for data integrity, confidentiality, authentication, availability, authorisation, access control, etc. Website security is especially important where critical information is stored in web applications and the transactions need to be safe, as in the case of defence and banking applications

SHWETA TYAGI

Before digging into the details of web application security testing, let us first take a brief overview of application security testing. Security testing can be divided into security functional testing and security vulnerability testing.

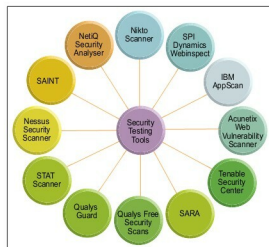


Fig. 1: Security testing tools

Security functional testing ensures that the software security functions are implemented correctly and are consistent with security requirements based on their specifications. Software security requirements mainly include data confidentiality, integrity, availability, authentication, authorisation, access

control, audit, privacy protection, security management, etc.

Security vulnerability testing is to discover security vulnerabilities as an attacker. Vulnerability refers to the flaws in system design, implementation, operation or management. It may be used to attack, resulting in a state of insecurity. Commonly found vulnerabilities in web applications include cross-site scripting, injection, security misconfiguration, session management and more.

Vulnerabilities of web applications may be accessed by using penetration testing. Source code analysis systems aim to help developers locate vulnerabilities in the underlying code of software programs and applications before they are put into production. Penetration testing is the practice of testing a computer system, network or web application to find vulnerabilities that an attacker could exploit.

Several researches are available which have compared some security testing tools from the viewpoint of their features, cost, services, functions and so on. In this article, we compare three tools—Wapiti, OWASP ZAP and Netsparker Community Edition in

terms of architecture, software requirement and generated results for different parameters.

Common web application vulnerabilities

The common vulnerabilities of web applications are cross-site scripting, SQL injection, broken authentication, cross-site request forgery and session management. These vulnerabilities appear significantly in the Web Hacking Incident Database (WHID).

SQL injection. It is a code injection technique, used to attack data-driven applications, in which malicious SQL statements are inserted into an entry field for execution. The best way of finding whether an application is vulnerable to attack is to ensure that all use of interpreters separates untrusted data from query. A rare and best way of attack is to inject malicious code into strings as metadata. Consequently, when the stored string is concatenated into a dynamic SQL query, the malicious code is executed. This can allow the tester to read and modify sensitive data contained in a database and take full control of the database server by exploiting vulnerabilities. Two attack scenarios are:

Scenario #1. The application uses untrusted data in the following vulnerable query:

String query = "SELECT * FROM